

MATRIZ CIA, CONTROLES Y RIESGOS RESIDUALES

Vista de auditoria para explicar que activos se protegen, que propiedad de seguridad domina en cada caso y que controles concretos existen en el codigo o la arquitectura.

CONFIDENCIALIDAD

Protege secretos, sesiones, datos personales y credenciales. Se apoya en Supabase Auth, JWT, RLS y en no exponer la service role key al frontend.

INTEGRIDAD

Protege que los datos no sean alterados por usuarios no autorizados. Se apoya en validacion de servicios, Query Builder, RLS y controles de rol.

DISPONIBILIDAD

Protege que el sitio y el panel sigan operando. Se apoya en frontend estatico, API separada, proveedores administrados y pruebas automatizadas.

MATRIZ POR ACTIVO					
Activo	Confidencialidad	Integridad	Disponibilidad	Controles principales	Riesgo residual
Credenciales	Alta	Alta	Media	Supabase Auth; hash interno; la app no guarda password.	Config incorrecta de Auth o mala gestion de cuentas.
JWT / session	Alta	Alta	Media	Bearer token; getUser(token); refresh client-side; HTTPS.	Robo de token por dispositivo comprometido.
Service role key	Critica	Critica	Media	Solo API/server; no Vercel frontend; uso auditado en aprobacion de rol.	Error operacional al copiar secretos al frontend.
profiles	Media	Alta	Media	RLS; auth.uid(); roles; Query Builder; service path controlado.	Políticas RLS mal migradas.
bookings	Media	Alta	Alta	Validacion de fecha/personas; Query Builder; RLS; controles admin/staff.	Errores de negocio si no se actualizan estados correctamente.

Activo	Confidencialidad	Integridad	Disponibilidad	Controles principales	Riesgo residual
role_change_requests	Media	Alta	Media	Roles permitidos; estados permitidos; RLS; admin-only approve.	Aprobacion indebida por cuenta admin comprometida.
Admin UI	Media	Alta	Alta	escapehtml; textContent; API auth; CORS; no passwords propios.	Dependencia de configuracion correcta de origen API.
API Parcial	Media	Alta	Alta	Helmet; CORS; requireAuth; HttpError; tests; validacion de servicios.	Caída del hosting Node o rate limits externos.

CONTROLES VERIFICABLES

Passwords
Supabase Auth gestiona hashes. La app solo guarda profiles sin columna password.

Prepared statements equivalentes
Repositorios usan Supabase Query Builder: insert, update, select, eq, in.

RLS
Postgres filtra acceso a filas bajo el contexto del JWT.

XSS
Backend rechaza markup HTML persistente; frontend usa escapehtml/textContent.

CORS
Preflight OPTIONS no requiere auth y solo permite orígenes configurados.

Secretos
Service role key solo debe vivir en API host, nunca en cliente.

CADENA DE DEFENSA POR SOLICITUD ADMIN

I.AUTH
Supabase valida credenciales y emite JWT. C

2. API GATE requireAuth valida Bearer token y carga profile C/I
3. SERVICIO Valida dominio: fechas, roles, longitudes, XSS. I
4. REPOSITORIO Query Builder evita SQL interpolado. I
5. POSTGRES/RLS Políticas por fila limitan lectura/escritura. C/I